ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric EcoStruxure Power Monitoring Expert (PME) · Component type: **Software Application (SAR) - power/energy monitoring & analysis software** · Target SL = SL 3

Where to work	**Web Applications › SETTINGS** is the security hub: **Users** (User Manager - standard / Windows / Windows-group accounts + access levels), **Security** (session timeout, authorized hosts, **Integrations › EWS Server**), and the TLS certificate (IIS). Windows-app clients: **Management Console** (device network setup, system config), **Vista** (diagrams), **Designer** (ION config). Databases in **SQL Server** (manage in SSMS). Prefer **Windows AD** users/groups. Installer + updates from Schneider (signed); the per-install **encryption key** is exported via the installer.
Ports / paths	**HTTPS 443 / HTTP 80** (Web Applications - keep HTTP off); **ION protocol TCP 7700** (+ UDP 7700 device discovery); **SQL Server TCP 1433**; device protocols **Modbus TCP 502**, **DNP3 20000**, **EtherGate 7801-7803**; **OPC / DCOM RPC 135**; NTP 123; Syslog 514. Four DBs: **ION_Data** (measurements), **ION_Network** (config), **ION_SystemLog** (events), **ApplicationModules**. Config + the encryption-key export live on the host.
Notes	SAR - Schneider EcoStruxure Power Monitoring Expert (PME). Monitoring/analysis app (not control SCADA). Confirm version (PME 2020/2021/2022/2023/2024) + patch level (Schneider SEVD / CISA - ICSA-25-037-01, ICSA-26-078-04, ICSA-23-290-01). Key facts: account passwords are encrypted at rest (SHA-512/AES-256, unique per-install key) but **monitoring & config data and device comms are NOT encrypted** - compensate with DB/host controls + segmentation. Prefer Windows/AD accounts to gain lockout + password policy.
How to read	Each row = native step-by-step (Web Apps SETTINGS / Management Console / SSMS) + command-level external-tool steps. Default read-only (review users/roles, cert, DB perms, config exports, screenshots). Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the PME database backups (ION_Data, ION_Network, ION_SystemLog, ApplicationModules), the Management Console + Web Apps configuration exports, the user / role exports, and the PME + Windows logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm every access path authenticates: the **Web Applications** and the Windows clients (**Vista, Designer, Management Console**) require login. There are **no pre-configured accounts** - only the one supervisor created at install; additional accounts are made in **Web Applications › SETTINGS › Users (User Manager)**. Prefer **Windows users/groups (AD)** so Windows lockout/password policy applies. No anonymous web access. **Test:** browse a Web App logged-out -> login required; confirm no shared/generic "supervisor" login is used operationally. **Ext. tools:** Web Apps User Manager (account list/types); browse logged-out -> login prompt; `nmap -p 80,443 .`	All Web + Windows clients authenticate; per-user accounts (AD-integrated where possible); no anonymous/shared path.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.2	Software process / device identification	Confirm server-to-server (primary/secondary servers, Engineering Clients via the PME network share) and device connections are identified: devices bound to known IPs in **Management Console** (ION 7700 / Modbus); EWS endpoints defined. Note device comms are unauthenticated - identity is by IP + segmentation. **Ext. tools:** Management Console (device/site list + IPs); Web Apps (EWS integration); Wireshark (partner IPs).	Server + device identities defined/bound; EWS endpoints controlled.	
SR/CR 1.3	Account management	In **User Manager** review the 3 account types (standard / Windows / Windows-group) + **access levels**; least privilege, named users, AD-managed where possible. Secure the auto-created **Windows accounts** (report subscriptions / DB maintenance - shared password, change via installer) and, if SQL Authentication is used, the **SQL accounts** + the SQL Express **sa** default password (change in SSMS). **Ext. tools:** Web Apps User Manager; installer (Windows-account password); SSMS (SQL logins / sa); AD group review.	Named least-privilege accounts; auto-created Windows/SQL account + sa passwords changed; defaults removed.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (AD/PME) and unique server/host identities across the PME system (server, secondary servers, engineering clients); no reuse. **Ext. tools:** User Manager; AD; PME system/host inventory.	Unique user and server identifiers; no reuse.	
SR/CR 1.5	Authenticator management	For **Windows/AD** users, password strength + lockout come from Windows (Schneider's recommended path - capture the policy). Standard PME users have weaker native policy - prefer Windows users. Change the shared Windows/SQL account passwords + the sa default. Account passwords are encrypted at rest (SHA-512/AES-256, unique per-install key) - **protect and back up the exported key**. MFA at the AD/SSO layer. **Ext. tools:** AD password/lockout policy (`gpresult /h gp.html`); User Manager (standard-user review); confirm sa/shared defaults changed; secure the key export.	Strong password policy (Windows/AD preferred); defaults changed; encryption key protected; MFA where feasible.	
SR 1.6	Wireless access management	**N/A.** Software application with no wireless interface; wireless is a host/network concern. **Ext. tools:** Confirm no software wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	PME installs a **self-signed certificate** (auto-configured) for HTTPS TLS 1.2 - **replace it with a CA-signed certificate** (IIS binding); confirm strong keys (>=2048 RSA/ECC), valid dates, and TLS 1.2 (1.3 for XL/Docker-collector systems). Disable weak TLS/ciphers. **Ext. tools:** `testssl.sh https://`; `openssl s_client -connect :443 | openssl x509 -noout -issuer -dates`.	CA-signed cert installed (default self-signed replaced); strong keys; TLS 1.2+.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the Web App and Windows-client (Vista/Designer/Management Console) logins mask password entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Use **Windows/AD users** to gain max-login-attempt lockout (Schneider TIP); standard PME users lack native lockout - compensate with Windows accounts + a reverse-proxy/WAF on the web tier; log failures to the SIEM. **Ext. tools:** AD lockout policy; Web-App failed-login behavior; Hydra (ISOLATED, authorized) to characterize; SIEM failed-auth.	Lockout via Windows/AD/proxy; failures logged; standard-user gap recorded/compensated.	
SR/CR 1.12	System use notification	Configure a use-notification banner where supported; enforce it on the Windows host (GPO logon banner) as the compensating control for the app clients. **Ext. tools:** Host `gpresult /h gp.html`; login screenshots.	Approved use notice at login/host.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 1.13	Access via untrusted networks	Confirm the PME server + SQL + web tier are reachable only from the trusted OT/DMZ zone; the Web Applications are fronted by a reverse proxy in the IDMZ with MFA; SQL (1433) / ION (7700) not exposed to untrusted networks; remote access via VPN/jump host. **Test:** from an untrusted VLAN, reach 443 / 1433 / 7700 -> must fail. **Ext. tools:** `nmap -Pn -p 80,443,7700,1433,135,502` from the untrusted side (expect filtered); firewall + IDMZ review.	PME/SQL/Web unreachable from untrusted networks; Web via IDMZ proxy + MFA.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm least privilege via **access levels** in User Manager: a user only performs actions their access level grants; a low-level user cannot manage users, change system configuration, or edit diagrams/reports. Windows-group mapping applies roles by AD group. **Test:** as a low-access-level user, attempt a config / user-management / control action -> denied. **Ext. tools:** User Manager (access-level matrix); low-privilege negative test in the Web App / Windows client.	Least privilege by access level enforced; negative test confirms denial.	
SR/CR 2.2	Wireless use control	**N/A.** Software application, no wireless interface. **Ext. tools:** Confirm no wireless; host/network layer governs.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the engineering/operator workstations and removable media (host device-control); only authorized installers/project content loaded; restrict who runs Management Console/Designer; protect the PME server **file share** (change+read, required for Engineering Clients/Secondary servers) with tight ACLs. **Ext. tools:** Host removable-media GPO; confirm installer provenance; file-share ACL review.	Portable/engineering media + the PME file share controlled.	
SR/SAR 2.4	Mobile code	Control mobile/embedded code: restrict **custom Web Application content / links** and any custom diagrams to trusted reviewed resources; set **authorized hosts** (framing/redirect allow-list) in Web Apps SETTINGS; only signed Schneider components/drivers installed. (Custom content must implement idle detection or sessions may not time out.) **Ext. tools:** Web Apps SETTINGS (authorized hosts + custom links review); installed-component signature review.	Only signed/required components; custom content allow-listed; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	PME auto times out inactive sessions - Web App clients are **logged out** and Windows clients (Vista/Designer/Management Console) are **locked**; default **20 min**, configurable in **Web Applications settings**; re-auth required. Confirm the timeout is set and the host OS screen-lock is enforced. **Ext. tools:** Web Apps SETTINGS (session timeout value); host inactivity-lock GPO.	Sessions time out/lock on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm active sessions time out/close and concurrent sessions are bounded/monitored (licensing + server config); Web-App sessions can be ended. **Ext. tools:** Web Apps (session review / timeout); Wireshark (session teardown).	Sessions terminable; concurrency bounded/monitored.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm security-relevant actions (login, user/config change, report/diagram change) are recorded with the acting user in the PME **system log** (ION_SystemLog) / diagnostics, and forwarded via **Syslog** to the SIEM. Per-user accounts give attribution. **Test:** change a setting / add a user -> a system-log/Syslog entry with the user + action + time. **Ext. tools:** Web Apps / system-log (ION_SystemLog) review; `nc -lu 514` / SIEM; trigger a test action.	Security actions logged with attribution and forwarded to the SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm ION_SystemLog + the databases are sized and maintained (the **ION_Data archive / database-maintenance** tasks) and events are offloaded to the SIEM, with alerting if forwarding fails. **Ext. tools:** Management Console / DB maintenance (archive task); SIEM source-silent alert.	Logs/DBs sized + maintained/offloaded; audit-failure alerting defined.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the PME servers, clients, and meters are NTP-synced so event/measurement and SIEM timestamps correlate (critical for power sequence-of-events). **Ext. tools:** `w32tm /query /status`; Wireshark `ntp`; meter time source.	Accurate, synchronized timestamps (SOE-grade).	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Enable **HTTPS TLS 1.2** on the Web Applications (replace the self-signed cert; disable HTTP 80); force **SQL Server connection encryption** for server↔DB (esp. distributed DB); XL systems use TLS 1.2/1.3 to Docker collectors. **Device comms (ION 7700 / Modbus) are NOT encrypted** - keep them contained in the segmented device zone. **Test:** confirm Web is HTTPS-only and server↔DB is encrypted; confirm device protocols stay in-zone. **Ext. tools:** `testssl.sh https://`; Wireshark (HTTPS web; SQL TLS; ION/Modbus cleartext in-zone only); `nmap -p 80` (HTTP off).	Web + server↔DB TLS-protected; HTTP off; unencrypted device comms contained in-zone.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the Schneider-**signed** PME - verify via Properties › **Digital Signatures** (signer must be *Schneider Electric*) before installing any update/component; host anti-malware / application whitelisting with PME-aware exclusions; restrict install/upgrade to admins; patch per Schneider SEVD / CISA. **Ext. tools:** `signtool verify /pa .exe` (or Digital Signatures tab); host AV/whitelisting; installed-component review.	Signed software validated (Schneider Electric signer); whitelisting active; install restricted; patched.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: User Manager/AD + no shared supervisor use, CA cert + HTTPS/HTTP-off, session timeout, authorized hosts, SQL auth mode + sa changed, syslog, and patch level, against the PME Cybersecurity-Reference baseline; compare config. **Ext. tools:** Web Apps SETTINGS review; SSMS (auth/logins); `nmap -p 80,443,1433,7700` ; version vs current.	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the four databases (**ION_Data / ION_Network / ION_SystemLog / ApplicationModules**), the config, and the **encryption-key export**: SQL + host ACLs, versioned offline backups, change detection. Note monitoring/config data is **not encrypted at rest** - rely on DB permissions + host disk encryption. **Ext. tools:** SSMS (DB roles/permissions); host ACL on config + key export; `certutil -hashfile SHA256` for drift.	DB/config integrity protected; unauthorized change detected; key export secured.	
SR/CR 3.5	Input validation	Confirm the Web Applications / reporting endpoints validate input (no injectable report/query paths) and patch known PME CVEs (Schneider SEVD - e.g. the deserialization/auth advisories in ICSA-25-037-01 / ICSA-26-078-04). **ISOLATED:** test the web tier. **Ext. tools:** Burp/ZAP against the Web App (ISOLATED); Nessus/OpenVAS for known CVEs; Schneider SEVD cross-check.	Inputs validated; known CVEs patched; no injectable path.	SAR-specific.
SR/CR 3.6	Deterministic output	**N/A.** PME is monitoring/analysis software and does not directly drive a physical output. If control is used (e.g. Vista/OPC command to a meter/relay), confirm command-confirmation and that the action is enforced/limited at the device. **Ext. tools:** Confirm no direct process output from PME; if control used, confirm device-side confirmation/limits.	N/A - justification recorded (monitoring software).	N/A
SR/CR 3.7	Error handling	Confirm errors/diagnostics are handled gracefully without leaking sensitive info; no plaintext secrets in logs/diagnostics; the system-log does not expose credentials. **Ext. tools:** Web Apps diagnostics / system-log review; log-content check.	Graceful error handling; no info leak.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.8	Session integrity	Confirm Web sessions are TLS-integrity-protected against replay/hijack and that PME **generated links** (for third-party integration) are authenticated; no unauthenticated/HTTP path remains. **Ext. tools:** Wireshark (session inspection); Web Apps (generated-links auth).	Sessions integrity-protected; generated links authenticated; no unauthenticated path.	
SR/CR 3.9	Protection of audit information	Protect ION_SystemLog + the Syslog transport + the SIEM store; restrict who can read/clear the log (access-level gated + SQL/host ACLs). **Ext. tools:** SSMS (ION_SystemLog permissions); Web Apps (log access level); SIEM access review.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, remove the four databases, config, certificates + private keys, the **encryption key**, the Windows/SQL account credentials, and backups; confirm no plaintext secrets persist; encrypt the host disk (monitoring/config data is not encrypted at rest by PME). **Ext. tools:** SSMS (drop/scrub DBs); remove certs/key export; confirm backups removed; BitLocker status.	DBs, secrets, certs, and the encryption key purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: TLS 1.2/1.3 on Web (+ Docker collectors), CA-signed cert, forced SQL connection encryption; account passwords are SHA-512/AES-256 at rest (protect the per-install key). Note device comms + stored monitoring data are not encrypted - compensate with segmentation + host disk encryption. **Ext. tools:** `testssl.sh https://`; SSMS (Force Encryption); confirm key-export protection + host disk encryption.	Modern TLS + managed certs; account creds encrypted at rest; unencrypted paths compensated.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the PME server + SQL server sit in a controlled OT zone; the Web tier is fronted by a reverse proxy in the IDMZ; only required flows cross (HTTPS, ION 7700, SQL 1433 internal, device protocols) to authorized peers; the device network is segmented; no flat convergence with IT. **Ext. tools:** `nmap -p 80,443,7700,1433,135,502,20000,7801-7803` per zone; firewall + IDMZ review.	PME/SQL in a segmented zone; Web via IDMZ proxy; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Monitoring platform with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Use the **Distributed Database** architecture to separate the SQL server from the PME application host; least-privilege service accounts; separate Engineering Clients / Secondary servers by role; scope the PME file share; where trust differs, separate hosts/zones. **Ext. tools:** System architecture review (standalone vs distributed DB); service-account + file-share scope; host topology vs criticality.	DB/app tiers and clients partitioned by role/criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm the PME system log / event data (ION_SystemLog) is readable/exportable by authorized staff and forwarded (Syslog) to the SIEM; monitor server/service + SQL health; passive OT IDS on the device segment. **Ext. tools:** Web Apps / SSMS (log export); Syslog + SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm resilience: primary/secondary server options + SQL sizing provide availability; the Web tier/reverse proxy rate-limits; host resource limits; do not co-host unrelated apps. Boundary controls bound floods. **Ext. tools:** System architecture (redundancy/secondary server); ISOLATED load/soak test; host resource monitor.	Server options + rate-limiting keep monitoring available under load.	
SR/CR 7.2	Resource management	Confirm bounded resources: SQL DB sizing + the **ION_Data archive / database-maintenance** tasks so the DB does not fill; session/connection limits; monitor CPU/mem/disk (a full ION_Data is a common availability failure). **Ext. tools:** Management Console / DB maintenance (archive/trim config); host disk + SQL size monitor.	Resources bounded; DB maintained; no exhaustion-based loss of service.	
SR/CR 7.3	Control system backup	Confirm the **four databases** + config + certificates + the **encryption key export** are backed up (versioned, offline) and a restore is tested on a spare for a known-good rebuild. The encryption key is REQUIRED to restore / add clients - protect and back it up separately. **Ext. tools:** SQL backup + config/cert/key backup review; restore test (lab).	Backups current (incl. encryption key); restore validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the PME Cybersecurity Reference / IT Guide: Windows/AD users, CA cert + HTTP off, session timeout, authorized hosts, disable unused integrations/features, least-privilege service account, SQL hardening (Windows auth preferred; change sa default; force encryption), patch PME + SQL + OS, remove sample/demo content. **Ext. tools:** Web Apps SETTINGS + SSMS review; `nmap -sTU -p-` (only required open); version vs current.	Least functionality; unused features disabled; SQL hardened; patched per the guide.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the PME version + build, installed modules/drivers, the SQL Server version, and the OS so vulnerabilities track against Schneider SEVD / CISA advisories (ICSA-25-037-01, ICSA-26-078-04, ICSA-23-290-01). **Ext. tools:** PME About / installed components; SSMS (SQL version); Schneider SEVD feed; passive OT IDS inventory.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Web Applications › SETTINGS (User Manager / Security)	Native user, role, TLS & security review (most FRs)	Review Users (standard/Windows/Windows-group + access levels), session timeout, authorized hosts, EWS integration, and the HTTPS certificate binding. Export settings as the baseline.	Read/authorized review.
Management Console	Device network + system config review (1.2, 2.9, 7.2)	Review the device/site list + IPs (ION 7700 / Modbus), ION_Data archive / database-maintenance tasks, and system configuration.	Read-only; authorized.
Vista / Designer	Windows-client access + diagram/ION config review (1.1, 2.1, 2.4)	Confirm login required and access-level enforcement; review diagrams/ION configuration and any custom content.	Read-only; authorized.
SQL Server Management Studio (SSMS)	Database security review (1.3, 3.4, 4.x, 7.6)	Review the auth mode (Windows vs SQL), the sa/login passwords, and per-DB roles/permissions on ION_Data / ION_Network / ION_SystemLog / ApplicationModules; enable Force Encryption.	Read-only; DBA-authorized.
signtool / Digital Signatures	Signed-installer validation (SAR 3.2)	`signtool verify /pa .exe` or Properties › Digital Signatures - signer must be Schneider Electric.	Read-only.
testssl.sh / openssl	TLS on Web (1.8, 3.1, 4.3)	`testssl.sh https://`; `openssl s_client -connect :443`; confirm TLS 1.2+, strong ciphers, CA-signed (default self-signed replaced).	Non-intrusive.
nmap	Port/service exposure & segmentation (1.13, 5.x, 7.6)	`nmap -p 80,443,7700,1433,135,502,20000,7801-7803` ; scan per zone; confirm HTTP/unused closed, SQL/ION not exposed off-segment.	Read-only; authorized.
Wireshark / tcpdump	Comms integrity (3.1, 3.8, 2.11)	SPAN/tap; confirm HTTPS on the web tier and encrypted server↔SQL; device ION/Modbus cleartext contained in-zone; inspect NTP.	Passive; SPAN/tap only.
Burp / ZAP / Nessus / OpenVAS + Schneider SEVD	Web validation & CVE scan (3.5, 7.8)	Proxy the Web App to test authz/input (ISOLATED); scan for known PME CVEs; cross-check Schneider SEVD / CISA (ICSA-25-037-01, ICSA-26-078-04, ICSA-23-290-01).	ISOLATED/representative; authorization.
Syslog listener / SIEM	Audit offload (2.8, 6.x)	`nc -lu 514`; confirm PME forwards system-log events; trigger a test action; confirm SIEM receipt.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.